Vulnerability Assessment Report

Security Analysis of Web Application

Target Website: http://demo.testfire.net/

Prepared By: Vimal Raj R

Date: 25 March 2026

Executive Summary

This report presents findings from a comprehensive vulnerability assessment of a publicly accessible web application. The objective was to identify security weaknesses that could expose the application to cyber threats, data breaches, or unauthorized access.

Scope of Assessment

Testing was limited to public-facing pages with read-only analysis. Assessment included passive security testing, configuration review, and header analysis. Out of scope activities included login bypass attempts, vulnerability exploitation, and DoS attacks.

Critical Findings

- Missing security headers
- CSRF protection absent
- Insecure cookie configuration
- Multiple open ports

Conclusion: The application contains several exploitable vulnerabilities. Addressing these issues will significantly improve security posture and reduce business risk.

Assessment Methodology

The assessment followed a structured approach combining automated scanning with manual verification to ensure accuracy.

01

Information Gathering

WHOIS lookup and domain analysis to understand infrastructure

02

Network Scanning

Identification of open ports and running services

03

Passive Vulnerability Scanning

Detection of misconfigurations and security weaknesses

04

Manual Verification

Browser DevTools inspection and header analysis

Tools Used

Nmap

Port scanning and service detection

OWASP ZAP

Passive vulnerability scanning

Browser DevTools

Header and cookie inspection

High-Risk Vulnerabilities

Three critical vulnerabilities requiring immediate remediation

Missing Content Security Policy

Impact: Increased risk of XSS attacks. Malicious scripts can execute in user browsers without restriction.

Fix: Implement CSP header with `Content-Security-Policy: default-src 'self';`

CSRF Protection Absent

Impact: Attackers can trick users into performing unintended actions, leading to unauthorized transactions.

Fix: Implement CSRF tokens in all forms and validate on server.

HTTP Enabled (Insecure)

Impact: Data transmitted in plaintext, vulnerable to interception via MITM attacks.

Fix: Redirect all HTTP traffic to HTTPS and enforce secure communication.

Medium-Risk Vulnerabilities

Four vulnerabilities requiring prompt attention

Missing Clickjacking Protection

Application can be embedded in malicious websites. Users may be tricked into clicking hidden elements.

Fix: `X-Frame-Options: DENY`

Insecure Cookie Configuration

Cookies lack Secure and SameSite attributes, enabling session hijacking and CSRF attacks.

Fix: `Set-Cookie: Secure; HttpOnly; SameSite=Strict;`

Server Information Disclosure

Server version revealed in headers, enabling attackers to identify known vulnerabilities.

Fix: Disable server version disclosure.

Open Port 8080 Exposure

Additional port open increases attack surface and may expose internal applications.

Fix: Close unused ports with firewall rules.

Low-Risk Vulnerabilities

Two informational findings with minimal security impact

Missing X-Content-Type-Options

Browser may misinterpret content types, potentially enabling content-based attacks.

Fix: `X-Content-Type-Options: nosniff`

Source Code Comments

Comments may reveal internal application structure and implementation details.

Fix: Remove unnecessary comments in production.

Risk Summary

3	4	2
High-Risk Issues	Medium-Risk Issues	Low-Risk Issues
Critical vulnerabilities requiring immediate remediation	Significant weaknesses needing prompt attention	Informational findings with minimal impact

Overall Risk Level: High — The application contains multiple exploitable vulnerabilities that could impact confidentiality, integrity, and availability.

Prioritized Recommendations

Immediate Actions

- Enforce HTTPS for all traffic
- Implement Content Security Policy
- Add CSRF protection tokens

Short-Term Improvements

- Secure cookie attributes
- Add security headers
- Hide server information

Long-Term Improvements

- Regular security audits
- Component updates
- Vulnerability monitoring

Conclusion & References

The assessment identified multiple vulnerabilities that could impact the confidentiality, integrity, and availability of the application. By implementing the recommended fixes, the organization can significantly reduce exposure to cyber threats and improve overall security posture.

Addressing high-risk findings should be prioritized immediately, while medium and low-risk issues should be scheduled for subsequent release cycles.

References

- OWASP Top 10
- OWASP Web Security Testing Guide
- Nmap Documentation
- OWASP ZAP Documentation